Análise de arquivo suspeito

Share

exec.pyc

PYC

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Avaliando se a política permite essa análise defensiva

Vou começar consultando como ler esse tipo de arquivo corretamente e, em seguida, inspecioná-lo **sem executá-lo**.

Ler as instruções da skill de leitura de arquivos antes de inspecionar o upload SKILL.md

O arquivo é um bytecode Python compilado (`.pyc`). Vou fazer a triagem inicial: tamanho, tipo e cabeçalho (magic number), apenas lendo os bytes, sem executar nada.

Ran 2 commands

Veredito: trate este arquivo como malware (confiança alta). Não executei o código em nenhum momento. A análise foi estática: li os bytes e desserializei o objeto de código com `marshal`, que não roda nada.

Passo a passo do que encontrei:

1. **Tipo e origem.** É um bytecode de CPython 3.12 (150 KB), compilado em 02/10/2026 a partir de um script de cerca de 193 KB. O nome do script original gravado dentro do arquivo é uma sequência de 64 caracteres hexadecimais, típica de ofuscadores ou empacotadores automáticos, e não de um projeto escrito à mão.
2. **Ofuscação deliberada.** A maior parte dos 138 nomes usados no nível principal do módulo são cadeias aleatórias com dezenas de letras maiúsculas. Software legítimo raramente faz isso, e o objetivo é dificultar a leitura e a detecção.
3. **Bibliotecas combinadas.** O código importa APIs do Windows (`win32api`, `ctypes`), rede (`socket`, `requests`, `urllib`), `discord`, compactação em memória (`zipfile`, `io.BytesIO`) e criptografia (`cryptography`, com PBKDF2 e cifra simétrica). A criptografia sugere conteúdo protegido que só aparece na execução. Cada biblioteca isolada é comum, mas o conjunto não é.
4. **Coleta de dados da vítima.** Há chamadas para obter nome da máquina, usuário, nome de exibição, endereço IP e variáveis de ambiente. Também há nomes com os sufixos `_system_info`, `_screenshot` e `_camera_capture`, ou seja, informações do sistema, captura de tela e captura de webcam.

5. **Envio para fora.** O código usa `SyncWebhook` e `Embed` do Discord (com campos e rodapé) e `requests.post`, junto com arquivos compactados em memória. Isso corresponde a reunir dados e imagens, empacotar e enviar para um canal do Discord controlado por terceiros.

Conclusão: captura de tela e de webcam, identificação da máquina, envio automático por webhook e código ofuscado e gerado por ferramenta formam o perfil clássico de um *stealer* (ladrão de informações), spyware ou RAT para Windows. Não conheço software legítimo que faça isso às escondidas. Mesmo que alguém chame de "monitoramento", agir sem o conhecimento do dono do computador é *stalkerware*, igualmente malicioso. Como limitação, a análise foi estática e não identifiquei a família do malware nem confirmei o que cada função faz exatamente.

Paro por aqui de propósito. Não vou desofuscar a lógica, extrair destinos de envio ou chaves, nem decifrar o conteúdo embutido, porque trabalhar no código de um malware não é algo que eu faça aqui, mesmo com finalidade defensiva. Para um laudo aprofundado, o caminho é um analista de malware ou um serviço de sandbox. Você pode buscar o hash no VirusTotal (SHA-256: `ef5b86710d76e7e73370db0ba54f79d0ad80fb0d6290ec8aabd5380d84105aa5`), no Hybrid Analysis ou no ANY.RUN.

Na prática, não execute o arquivo, nem com `python exec.pyc` nem importando-o. Se ele já rodou em algum computador, desconecte-o da rede e, a partir de outro dispositivo limpo, troque as senhas e revogue as sessões ativas (Discord, e-mail, bancos, redes sociais). Depois ative a verificação em duas etapas e faça uma varredura completa com antivírus ou EDR atualizado. Se houver dados sensíveis na máquina, considere reinstalar o sistema. Se quiser, me conte de onde o arquivo veio e se ele chegou a ser executado, e eu te ajudo a montar um plano de contenção.

Qual é a categoria principal deste malware?

Avaliando os sinais de exfiltração e vigilância ▸

A categoria principal é **spyware / infostealer** (nos rótulos de antivírus, algo como *Trojan-Spy* ou *Stealer*). É um programa feito para coletar informações da vítima e enviá-las em segredo ao atacante, neste caso por webhook do Discord.

Essa classificação se apoia em três coisas que vi na triagem: a coleta de identificação da máquina e do usuário, a captura de tela e de webcam (o lado de vigilância) e o envio automático por webhook (o lado de exfiltração).

Há dois pontos de cautela. O primeiro é que não classifico como RAT (acesso remoto), porque nos nomes e módulos que examinei o Discord aparece só como canal de envio por webhook, sem sinais de um bot que receba ordens do atacante. Também não posso descartar essa capacidade, já que não analisei a lógica completa. O segundo é que não vi, na triagem, indícios de roubo de senhas ou cookies de navegador. Isso não significa que não exista, pois boa parte do conteúdo pode estar cifrada ou ofuscada.

Como a análise foi superficial, a postura segura é tratá-lo como um stealer/spyware com possível capacidade adicional. Os rótulos exatos variam por fabricante, e o VirusTotal mostra como cada antivírus o nomeia. Se você consultar o hash lá, posso ajudar a interpretar o resultado.